

Nexora Corporate Knowledge Base: Security Policy v2.1

Target Role: ALL | Version: Official | Published: 2026-09-25

1. Workstation & Physical Security

Employees must ensure workstations are locked whenever left unattended (Win+L / Cmd+Ctrl+Q). Workstation screen lock timeout is enforced at 5 minutes of inactivity. Physical laptops must use full-disk encryption (FileVault / BitLocker).

2. Password & Authentication Standards

Mandatory password rotation occurs every 90 days. Passwords must contain a minimum of 16 characters including uppercase, lowercase, numbers, and symbols. Multi-Factor Authentication (MFA / 2FA) using hardware security keys or authenticator apps (TOTP) is strictly enforced on all corporate SSO accounts. SMS-based 2FA is prohibited.

3. Phishing Simulations & Awareness

Security awareness drills and quarterly phishing simulations are conducted by the InfoSec team. Employees who fail simulated drills are required to complete a 30-minute refresher security course within 5 business days.

4. Incident Reporting Protocol

Any suspected security anomaly, leaked credential, lost laptop, or malware alert must be reported to security@nexora.com and in the private Slack channel #security-alerts within 15 minutes of discovery.

5. Zero Trust Access Control

Access to internal networks, databases, and admin dashboards requires connection through Nexora's Zero-Trust VPN with device posture compliance checks. Production access requires just-in-time (JIT) privilege elevation.

6. Secrets Handling for Engineers

Application secrets, API tokens, and credentials must never be hardcoded, committed to repositories, or pasted into Slack. Local development secrets are injected via HashiCorp Vault CLI or 1Password developer plugins, and pre-commit TruffleHog scans enforce this automatically.

7. Vendor and Third-Party Reviews

New vendors with access to Nexora or customer data undergo a security review by InfoSec before procurement, covering encryption posture, access controls, and incident notification commitments.

8. Training Compliance Tracking

Completion of compliance training and phishing refresher courses is tracked per employee. Overdue training blocks production access elevation until resolved, consistent with Zero Trust least-privilege principles.

